3-3 Threats and Countermeasures in Information Security [3]

Point!

1 Fraudulent Billing

([1]**Fraudulent billing**): A scam in which a person is billed for a fictitious service they have never used, with the intent to fraudulently extract money.

([2]**One-click fraud**): A scam where clicking a URL in a website or email automatically triggers a message pretending a contract has been concluded, followed by an exorbitant payment demand.

2 Unauthorized Acquisition of Information

(1) ([3]**Phishing**) : A scam that uses fake websites disguised as financial institutions or public agencies to steal personal information such as PINs or account details.

(2) ([4]**Social engineering**) : A method of fraudulently obtaining information by exploiting human psychology, carelessness, or lack of awareness.

[1] ([5]**Impersonation**) : The act of pretending to be someone else—such as making a phone call in their name—to obtain information.

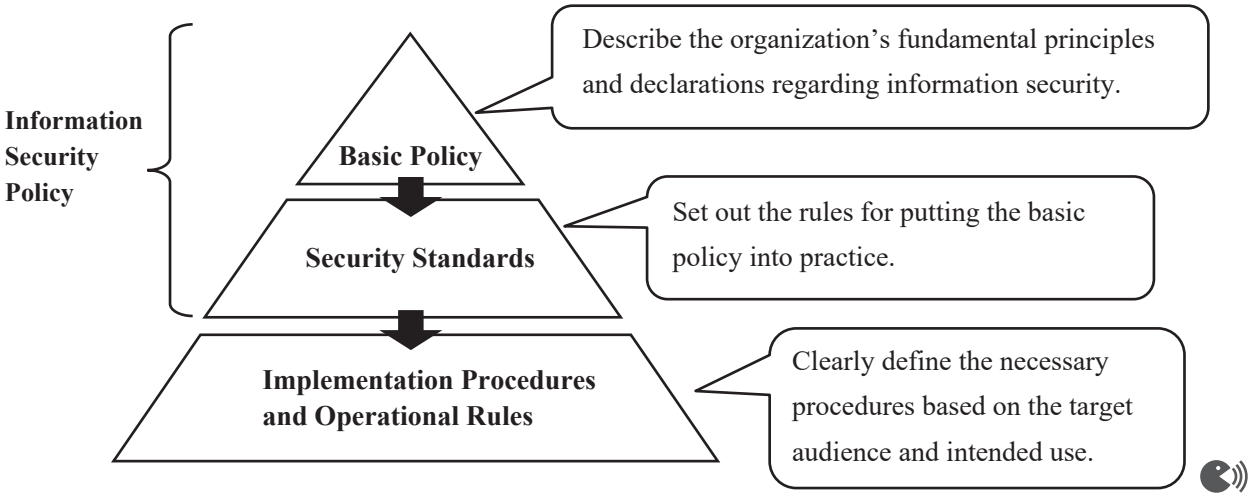
[2] ([6]**Shoulder surfing**) : The act of peeking over someone's shoulder to steal passwords or PIN codes.

[3] ([7]**Dumpster diving**) : The act of rummaging through trash to obtain discarded confidential information.

(3) ([8]**Skimming**) : The act of illegally extracting data from someone's credit or debit card and using it to create a counterfeit card.

3 Information security policy

([9]**Information Security Policy**) : A set of fundamental rules and guidelines established by a company or organization to maintain and protect information security.



Warm Up

Answer the following questions.

(1) Choose the one that correctly describes phishing from the options **A** to **D** below, and answer using the letter.

A A program that unknowingly steals personal information from inside a computer and sends it to a third party.

B Pretending to be an email from a financial institution to lure someone to a fake website and illegally obtain their PIN or credit card number.

C Clicking a URL once in a website or email triggers a false declaration of contract and a demand for a large payment.

D Being billed for a service you don't recognize and being defrauded of money.

(2) Choose *all* that correspond to social engineering from the options **A** to **D** below, and answer using the letters.

A Disabling access to data on a computer and demanding a ransom for its recovery.

B Creating a fake website posing as a bank to steal the PIN of a bank account.

C. Eavesdropping on conversations with other users.

D Rummaging through trash to obtain discarded confidential information.

Explanation

(1) A is spyware, C is one-click fraud, and D is fraudulent billing. Answer: **B**

(2) A is ransomware, B is phishing. Answers: **C, D**

Try

Read the following passage and answer the questions that follow.

As more people use the internet, cases of fraud involving the misuse of computers and smartphones are also increasing. For example, there are scams where simply clicking a URL on a website is treated as agreeing to a service contract, and a large fee is demanded ([1]), or emails pretending to be from financial institutions lead users to fake websites in order to steal PINs or credit card numbers ([2]). Various deceptive methods exist. In addition, (A)exploiting gaps in human psychology or carelessness can also lead to the unauthorized acquisition of information.

(1) Write the terms that best fit in blanks [1] and [2].
(2) What is the term used to describe the kind of activity mentioned in the underlined part A?
(3) Choose *all* that are related to the answer in (2) from the options **A** to **D** below, and answer using the letters.
- **A** Individuals can communicate with each other over the internet.
- **B** Data on a computer is made inaccessible, and a ransom is demanded for its recovery.
- **C** Eavesdropping on conversations with other users.
- **D** Peeking while someone is entering their user ID or password.

Exercise

1 Answer the question to the following.

(1) For each of the following sentences, choose the most closely related option from the options **A** to **E** below, and answer using the letters.
- [1] Being charged a usage fee simply by clicking a link, as if you had joined or signed a contract.
- [2] Pretending to be a financial institution to trick users into entering their user ID and password, which are then misused.
- [3] A basic policy established by a company or organization to maintain information security.
- [4] Illegally extracting information from someone else's credit card or bank card.

A Phishing **B** One-click fraud **C** Skimming
D Information security policy **E** Social engineering

(2) Choose *all* that fall under social engineering from the options **A** to **D** below, and answer using the letters.
- **A** Calling from outside while pretending to be an employee, in order to extract confidential internal information.
- **B** Being billed for a fictitious service you don't recognize and being defrauded of money.
- **C** Rummaging through trash to obtain discarded confidential information.
- **D** Running a program that causes malicious software to be downloaded without the user's knowledge.